API Specification: KitchenFlow Restaurant Order & Kitchen Display System

Document ID: KF-API-001 · Version 0.1 (draft) · 30 October 2026 · Author: Rathi · Related: KF-PDD-001, KF-SRS-001, KF-SAD-001, KF-DBD-001

1. Introduction

1.1 Purpose

This document is the contract of the KitchenFlow REST and server-sent-events API: every endpoint, its roles and limits, request and response schemas, validation rules, and every success, error and edge case a client can meet. It is document 5 of 7. It implements SRS sections 5 and 10, SAD sections 5, 6 and 9 and DBD sections 5 and 8. The OpenAPI definition is generated from the code (FR-SYS-02); this document is what that generated definition and the contract tests are checked against.

1.2 Scope and audience

In scope: the web clients (cashier POS, station boards, manager board, status board, admin screens), a future Android kitchen display, test authors and reviewers. Out of scope: internal Java interfaces and the database.

1.3 How to read this document

Endpoints have IDs such as O-01 (section 4 lists them all). Priorities are M, S and C as in the SRS. A feature marked (proposed) is added by this document and listed in section 17.2 for the SRS change control. Examples are illustrative: ids and timestamps vary. Every endpoint section ends with a table of its cases, so a test author can derive one test per row.

2. API conventions

2.1 Protocol and formats

Topic	Rule
Base path	/api/v1 on the Nginx host. A breaking change would introduce /api/v2 and run both until clients have moved; additive changes (new optional fields, new endpoints) stay in v1.
Media types	application/json (UTF-8) for requests and responses; text/event-stream for streams; text/csv for report exports (Could); application/pdf for the printable bill (Could). A body with another Content-Type returns 415; an unsatisfiable Accept returns 406.
Methods	GET never changes state. POST creates or performs an action. PUT replaces. PATCH changes only the fields sent. DELETE removes. Any other method returns 405 with an Allow header.
Naming	JSON fields in camelCase, enum values in UPPER_SNAKE_CASE, paths in lowercase kebab-case.
Identifiers	Numeric 64-bit integers, always below 2^53 so JavaScript reads them exactly. Order numbers (KF-YYYYMMDD-NNNN, four or more digits) are display values, searched by query parameter and never used in paths.
Money	JSON strings with exactly two decimals, for example 513.72, never JSON numbers. A money field sent as a number returns 400; one with other than two decimals returns 422 INVALID_SCALE. GST rates are strings with two decimals, for example 5.00.
Date and time	Instants are ISO 8601 in UTC with milliseconds and a Z suffix. A business day is a date, YYYY-MM-DD. Clients display time in Asia/Kolkata.
Strings	Leading and trailing whitespace is trimmed. A required string that is blank after trimming counts as missing. Control characters are rejected (INVALID_CHARACTERS). Lengths count characters; passwords count bytes.
Nulls	Responses always include every documented field; an absent value is null. In requests a missing required field and an explicit null are both REQUIRED. PATCH changes only the fields present.

Topic	Rule
Unknown input	Unknown JSON properties and unknown query parameters are rejected with 400 MALFORMED_REQUEST naming the offender. This blocks mass assignment and silent typos (NFR-SEC-02).
Body size	At most 1 MB; larger returns 413 PAYLOAD_TOO_LARGE.
Compression	gzip is accepted for responses above 1 KB, never for streams.

2.2 Authentication

- Every endpoint except those marked Public needs a bearer JWT in the Authorization header. The access token lives 15 minutes and holds sub (user id), role, stations (ids), jti, iat and exp. It carries no personal data.
- 401 UNAUTHENTICATED, with a WWW-Authenticate: Bearer header, when the token is missing, malformed, wrongly signed or expired. 403 FORBIDDEN when the user is authenticated but the role or station binding does not allow the call.
- Deactivating a user stops login and refresh at once; an access token already issued stays valid until it expires, at most 15 minutes (FR-AUTH-05).
- Refresh token (Should): cookie kf_refresh, HttpOnly, Secure, SameSite=Strict, path /api/v1/auth, lifetime 8 hours (configurable), rotated on every use. Endpoints that read the cookie also check the Origin header against the CORS allow-list and return 403 on a mismatch.

2.3 Headers

Header	Direction	Purpose
Authorization	Request	Bearer access token
Content-Type	Request	application/json on every request with a body
Accept	Request	application/json by default; text/event-stream for streams
Idempotency-Key	Request	POST /orders only (section 2.7)
If-None-Match	Request	GET /menu (section 2.9)

Header	Direction	Purpose
X-Correlation-Id	Both	Optional from the client (up to 64 characters from letters, digits, dot, underscore, hyphen); generated when absent or invalid; always returned and repeated in every error body
ETag	Response	GET /menu
Location	Response	Every 201
Retry-After	Response	429 and 503, in seconds
X-RateLimit-Limit, X-RateLimit-Remaining	Response	Rate-limited classes (section 2.10)
Idempotency-Replayed	Response	true on a replayed response
Cache-Control	Response	no-store on authenticated responses; no-cache with an ETag on /menu
WWW-Authenticate	Response	On 401
Allow	Response	On 405

2.4 Error envelope

Every error, from every layer, has one shape (FR-SYS-01). The errors array is present only for VALIDATION_FAILED and ITEM_UNAVAILABLE; details carries structured context for other codes and is null otherwise. No error ever contains a stack trace or internal names.

```
{
  "timestamp": "2026-10-30T09:15:30.456Z",
  "status": 422,
  "code": "VALIDATION_FAILED",
  "message": "The request has 2 invalid fields.",
  "path": "/api/v1/orders",
  "correlationId": "9b2f6c1e-7d54-4a39-8c0e-2f1d7a6b5e44",
  "errors": [
    { "field": "lines[0].quantity", "code": "OUT_OF_RANGE", "message":
"Quantity must be between 1 and 50." },
    { "field": "lines[1].itemId", "code": "ITEM_UNAVAILABLE", "message":
"Cola is currently unavailable." }
  ],
  "details": null
}
```

Code	Shape of details
STALE_VERSION	current: the current representation of the resource
INVALID_TRANSITION	currentStatus, requestedOperation, reason (for example RECALL_WINDOW_EXPIRED, ORDER_COMPLETED)
OUT_OF_STOCK	items: list of itemId, name, requested, available
AMOUNT_MISMATCH	expectedAmount
RATE_LIMITED	rateClass, retryAfterSeconds
RESOURCE_IN_USE	references: list of type and count
SERVICE_BUSY	reason: POOL, LOCK_TIMEOUT or QUERY_TIMEOUT
IDEMPOTENCY_KEY_REUSED	firstSeenAt

2.5 Order of checks

Every request meets the same checks in the same order, so the first failing check decides the response.

Step	Check	Responses
1	Edge limits at Nginx: request size, connections, per-address rate	413, 429
2	Syntax: method, Content-Type, Accept, JSON parsing, unknown properties and parameters, value types	405, 415, 406, 400
3	Authentication	401
4	Application rate limit for the user and endpoint class	429
5	Authorization: role, then station binding	403
6	Lookup of resources named in the path	404
7	Field validation; all violations are collected and reported together	422
8	Idempotency check (POST /orders): replay or key reuse	Replay, 422
9	Business rules inside the transaction: state, stock, version, uniqueness, amounts	409, 422
10	Infrastructure faults: pool, lock or statement timeout	503, 500

Two consequences. Role checks come before lookups, so a Kitchen user calling an order endpoint gets 403 even for an id that does not exist. Unknown paths return 404 only after authentication.

2.6 Pagination, sorting and filtering

- Page parameters: page (starting at 0, default 0), size (1 to 100, default 20) and sort as field,asc or field,desc. Each endpoint lists its sortable fields and default; ties are broken by id.
- List envelope: content (array) and page with number, size, totalElements and totalPages.

- Cursor variant (orders and audit): send cursor with the opaque value from the previous response and size; the response carries content and nextCursor (null on the last page) and omits totals. Sort is fixed (newest first). Combining cursor with page returns 400. A tampered cursor returns 400.
- Filters are exact matches. A multi-value filter is comma separated with at most 10 values, for example status=CREATED,IN_KITCHEN. Booleans are true or false in lowercase.

Case	Result
Page beyond the last	200 with empty content
size 0 or above 100, or a negative page	422 OUT_OF_RANGE on that parameter
Unknown sort field	422 UNKNOWN_SORT_FIELD
Sort direction other than asc or desc	422 INVALID_ENUM
Empty filter value, for example status=	422 INVALID_FORMAT
Unknown filter parameter	400 MALFORMED_REQUEST
Filter matches nothing	200 with empty content, never 404

2.7 Idempotency

POST /orders accepts an Idempotency-Key header: 1 to 80 characters from letters, digits, underscore and hyphen; a UUID v4 is recommended. The header is optional, but a request without it cannot be retried safely. Scope is per user and retention is 24 hours (BR-15, FR-ORD-10).

Situation	Result
First use of the key	Processed normally; the response is stored with the key
Same key and identical payload, first request finished	The original status and body are replayed with Idempotency-Replayed: true; no new order
Same key arrives while the first request is still running	The duplicate waits (up to the 2-second lock timeout), then replays. If the first fails and rolls back, the duplicate is processed as a first use

Situation	Result
Same key, different payload	422 IDEMPOTENCY_KEY_REUSED; nothing is created
First request failed with 4xx or 5xx	Nothing was stored; a retry runs again
More than 24 hours later	The key is forgotten and reuse creates a new order, so never reuse a key
Another user sends the same key	Independent; scope is per user
Malformed key	422 VALIDATION_FAILED with field Idempotency-Key, code INVALID_FORMAT

Payload identity is the SHA-256 of the canonical JSON body (keys sorted, whitespace removed), so field order does not matter. A replay returns the original snapshot, not the order's current state; clients fetch the order for that. Other endpoints ignore the header and rely on state checks instead.

2.8 Optimistic concurrency

Representations of orders, tickets, menu items, users and stock carry a version. Mutating requests marked expectedVersion must send the version the client last saw. A mismatch returns 409 STALE_VERSION with the current representation in details.current. The client re-reads, re-applies its intent and retries; it never retries blindly.

A second form of conflict is an action that was already applied (a double tap, or two people acting together). It returns 409 INVALID_TRANSITION whose details.currentStatus already equals the target state. Clients treat that case as success for start, bump, cancel and complete.

2.9 Caching and conditional requests

Only GET /menu is cacheable: it returns an ETag built from the menu version and a hash of the filters, with Cache-Control: no-cache. A request with a matching If-None-Match returns 304 with no body. Every other authenticated response is Cache-Control: no-store.

2.10 Rate limiting

Two layers apply (SAD 5.2). Nginx limits each address coarsely; the application limits each user by endpoint class with token buckets. The class of every endpoint is in section 4.

Class	Key	Burst	Refill
LOGIN	Address and username	5	5 per 10 minutes
REFRESH	User	10	10 per 10 minutes
ORDER_WRITE	User	30	30 per minute
TICKET_ACTION	User	120	120 per minute
READ	User	300	300 per minute
REPORT	User	10	10 per minute
ADMIN_WRITE	User	60	60 per minute
BOARD_READ	Address	60	60 per minute
SSE_CONNECT	User or address	10	10 per minute

Open streams are also capped at 3 per user, 20 per address and 50 in total. A rejected request returns 429 RATE_LIMITED with Retry-After and details.rateClass. Clients wait at least Retry-After, add random jitter, and never retry a write without its Idempotency-Key. Many devices behind one address share the address-keyed limits: status boards should use the stream and, if they poll, no faster than every 3 seconds.

2.11 CORS and transport

HTTPS outside local development. CORS allows only configured origins, the methods GET, POST, PUT, PATCH, DELETE and OPTIONS, and the request headers Authorization, Content-Type, Idempotency-Key, If-None-Match and X-Correlation-Id. Exposed response headers: X-Correlation-Id, ETag, Retry-After, Idempotency-Replayed and the X-RateLimit headers. Preflight answers are cached for 600 seconds. Credentials (the refresh cookie) are allowed only on the auth endpoints.

3. Error catalogue

3.1 Error codes

Code	HTTP	Meaning	Typical triggers
MALFORMED_REQUEST	400	The request cannot be parsed	Invalid JSON, wrong value type, unknown property or parameter, bad path id, tampered cursor
UNAUTHENTICATED	401	Credentials missing or invalid	No token, expired token, wrong password
FORBIDDEN	403	Authenticated but not allowed	Wrong role, unbound station, Origin mismatch
NOT_FOUND	404	The resource does not exist	Unknown id, unpaid order has no payment
METHOD_NOT_ALLOWED	405	Method not supported on this path	DELETE on /orders
NOT_ACCEPTABLE	406	Accept cannot be satisfied	Accept: application/xml
INVALID_TRANSITION	409	The operation is not allowed in the current state	Edit after payment, bump a NEW ticket, cancel a READY order
STALE_VERSION	409	The resource changed since the client read it	Two cooks update one ticket
OUT_OF_STOCK	409	Not enough stock	Last unit sold
PAYMENT_ALREADY_RECORDED	409	The order already has a payment	Double tap, two terminals

Code	HTTP	Meaning	Typical triggers
RESOURCE_IN_USE	409	The resource is referenced and cannot be removed or deactivated	Delete an item that was ordered
PAYLOAD_TOO_LARGE	413	Body above 1 MB	Oversized request
UNSUPPORTED_MEDIA_TYPE	415	Content-Type is not JSON	text/plain body
VALIDATION_FAILED	422	One or more field rules failed; errors lists all	Missing field, bad range, unknown id inside the body
ITEM_UNAVAILABLE	422	Only item-availability problems failed	Unavailable or inactive item in an order
AMOUNT_MISMATCH	422	Payment amount differs from the order total	Order edited before payment
IDEMPOTENCY_KEY_REUSED	422	Key reused with a different payload	Client bug
RATE_LIMITED	429	A limit was exceeded	Login lockout, runaway retry loop
INTERNAL_ERROR	500	Unexpected failure	Defect; details only in the logs
SERVICE_BUSY	503	Temporarily overloaded	Pool exhausted, lock or statement timeout

Codes METHOD_NOT_ALLOWED, NOT_ACCEPTABLE, RESOURCE_IN_USE, PAYLOAD_TOO_LARGE, UNSUPPORTED_MEDIA_TYPE and SERVICE_BUSY are additions to SRS section 10 (section 17.2).

3.2 Field error codes

Used in errors[].code when the top-level code is VALIDATION_FAILED or ITEM_UNAVAILABLE.

Code	Meaning
REQUIRED	Missing, null or blank
INVALID_FORMAT	Wrong pattern, for example a malformed key or date
INVALID_ENUM	Value not in the allowed set
OUT_OF_RANGE	Number outside its limits
TOO_LONG, TOO_SHORT	String length outside its limits
TOO_MANY, TOO_FEW	Array size outside its limits
INVALID_SCALE	Money or rate without exactly two decimals
INVALID_CHARACTERS	Control characters present
DUPLICATE_VALUE	Value already taken or repeated in the request
UNKNOWN_ID	A referenced id does not exist
UNKNOWN_SORT_FIELD, UNKNOWN_KEY	Sort field or configuration key not recognised
INVALID_RANGE	A from value is after its to value, or a range is too long
ONE_OF_REQUIRED	Exactly one of several fields must be given
NOT_APPLICABLE	Field not allowed in this situation
ITEM_UNAVAILABLE, ITEM_INACTIVE	The item is marked unavailable, or is inactive
MODIFIER_NOT_ALLOWED, MODIFIER_UNAVAILABLE	Modifier does not belong to the item, or is inactive
MODIFIER_MIN, MODIFIER_MAX	Fewer or more selections than the group allows
MIN_EXCEEDS_OPTIONS	A group's minimum is more than its active options

Code	Meaning
STATION_INACTIVE, LAST_STATION_FOR_ITEM	Station is inactive, or it is the only station of an active item
NOT_TRACKED, NEGATIVE_STOCK, STOCK_ZERO	Stock rules (section 8)
INCORRECT_PASSWORD, WEAK_PASSWORD	Password rules (section 6)
SELF_LOCKOUT, LAST_ADMIN	An admin change that would remove the last way to administer the system

3.3 Status codes in use

Status	Used for
200	Successful read, update or action
201	Resource created; Location header set
204	Success with no body: logout, delete, password changes
304	Menu unchanged
400, 401, 403, 404, 405, 406	Syntax, authentication, authorization, lookup
409	State, version, stock, payment and reference conflicts
413, 415	Size and media type
422	Field validation and rule violations on a well-formed request
429	Rate limits and caps
500, 503	Defects, and temporary overload

4. Endpoint index

The API has 73 endpoints. Roles: Public needs no token; Staff is any authenticated user; Kitchen is limited to the user's bound stations; Manager and Admin are as in SRS section 3.2. The class column is the rate-limit class (section 2.10). All paths are relative to /api/v1 except the platform endpoints in 4.6.

4.1 Authentication and users

ID	Method and path	Roles	Class	Pri	SRS
A-01	POST /auth/login	Public	LOGIN	M	FR-AUTH-01
A-02	POST /auth/refresh	Refresh cookie	REFRESH	S	FR-AUTH-07
A-03	POST /auth/logout	Refresh cookie	REFRESH	S	FR-AUTH-07
A-04	GET /auth/me	Staff	READ	M	FR-AUTH-03
A-05	POST /auth/change-password	Staff	REFRESH	S (proposed)	Section 17.2
U-01	GET /admin/users	Admin	READ	M	FR-AUTH-05
U-02	POST /admin/users	Admin	ADMIN_WRITE	M	FR-AUTH-05
U-03	GET /admin/users/{id}	Admin	READ	M	FR-AUTH-05
U-04	PATCH /admin/users/{id}	Admin	ADMIN_WRITE	M	FR-AUTH-04, 05
U-05	POST /admin/users/{id}/password-reset	Admin	ADMIN_WRITE	S (proposed)	Section 17.2

4.2 Reference data, configuration and menu

ID	Method and path	Roles	Class	Pri	SRS
S-01	GET /stations	Staff	READ	M	FR-CFG-01
S-02	POST /admin/stations	Admin	ADMIN_WRITE	M	FR-CFG-01
S-03	PATCH /admin/stations/{id}	Admin	ADMIN_WRITE	M	FR-CFG-01
C-01	GET /admin/config	Admin	READ	M	FR-CFG-01
C-02	PATCH /admin/config	Admin	ADMIN_WRITE	M	FR-CFG-01
M-01	GET /menu	Staff	READ	M	FR-MENU-06

ID	Method and path	Roles	Class	Pri	SRS
M-02	GET /admin/categories	Admin	READ	M	FR-MENU-01
M-03	POST /admin/categories	Admin	ADMIN_WRITE	M	FR-MENU-01
M-04	PATCH /admin/categories/{id}	Admin	ADMIN_WRITE	M	FR-MENU-01
M-05	GET /admin/items	Admin	READ	M	FR-MENU-02
M-06	POST /admin/items	Admin	ADMIN_WRITE	M	FR-MENU-02
M-07	GET /admin/items/{id}	Admin	READ	M	FR-MENU-02
M-08	PATCH /admin/items/{id}	Admin	ADMIN_WRITE	M	FR-MENU-02, 08
M-09	DELETE /admin/items/{id}	Admin	ADMIN_WRITE	M	FR-MENU-05
M-10	PUT /admin/items/{id}/stations	Admin	ADMIN_WRITE	M	BR-09
M-11	POST /admin/items/{id}/modifier-groups	Admin	ADMIN_WRITE	M	FR-MENU-03
M-12	PATCH /admin/modifier-groups/{id}	Admin	ADMIN_WRITE	M	FR-MENU-03
M-13	DELETE /admin/modifier-groups/{id}	Admin	ADMIN_WRITE	M	FR-MENU-03
M-14	POST /admin/modifier-groups/{id}/modifiers	Admin	ADMIN_WRITE	M	FR-MENU-03
M-15	PATCH /admin/modifiers/{id}	Admin	ADMIN_WRITE	M	FR-MENU-03
M-16	DELETE /admin/modifiers/{id}	Admin	ADMIN_WRITE	M	FR-MENU-03
M-17	PATCH /items/{id}/availability	Manager, Admin	ADMIN_WRITE	M	FR-MENU-04
M-18	GET /admin/combos	Admin	READ	S	FR-MENU-07
M-19	POST /admin/combos	Admin	ADMIN_WRITE	S	FR-MENU-07
M-20	PATCH /admin/combos/{id}	Admin	ADMIN_WRITE	S	FR-MENU-07
M-21	DELETE /admin/combos/{id}	Admin	ADMIN_WRITE	S	FR-MENU-07

4.3 Inventory (Should)

ID	Method and path	Roles	Class	Pri	SRS
I-01	GET /stock	Manager, Admin	READ	S	FR-INV-01
I-02	POST /items/{id}/stock-adjustments	Manager, Admin	ADMIN_WRITE	S	FR-INV-05
I-03	GET /items/{id}/stock-adjustments	Manager, Admin	READ	S	FR-INV-05

4.4 Orders and payments

ID	Method and path	Roles	Class	Pri	SRS
O-01	POST /orders	Cashier, Manager	ORDER_WRITE	M	FR-ORD-01 to 04, 10
O-02	GET /orders	Cashier, Manager	READ	M	FR-ORD-09
O-03	GET /orders/{id}	Cashier, Manager	READ	M	FR-ORD-09
O-04	PUT /orders/{id}	Cashier, Manager	ORDER_WRITE	M	FR-ORD-06
O-05	POST /orders/{id}/cancel	Cashier (CREATED), Manager	ORDER_WRITE	M	FR-ORD-07
O-06	POST /orders/{id}/complete	Cashier, Manager	ORDER_WRITE	M	FR-ORD-08
O-07	PATCH /orders/{id}/rush	Manager	ORDER_WRITE	S	FR-ORD-11
O-08	GET /orders/{id}/tickets	Cashier, Manager	READ	M	FR-KDS-09
P-01	POST /orders/{id}/payments	Cashier, Manager	ORDER_WRITE	M	FR-PAY-01 to 04, 06
P-02	GET /orders/{id}/payment	Cashier, Manager	READ	M	FR-PAY-01
P-03	GET /orders/{id}/bill	Cashier, Manager	READ	M	FR-PAY-05
P-04	GET /orders/{id}/bill.pdf	Cashier, Manager	READ	C	FR-PAY-08
P-05	GET /refunds	Manager	READ	S	FR-PAY-07
P-06	POST /refunds/{id}/complete	Manager	ORDER_WRITE	S (proposed)	Section 17.2

4.5 Kitchen, status board and streams

ID	Method and path	Roles	Class	Pri	SRS
K-01	GET /stations/{id}/tickets	Kitchen (bound), Manager	READ	M	FR-KDS-02
K-02	GET /tickets/{id}	Kitchen (bound), Manager	READ	M	FR-KDS-02
K-03	POST /tickets/{id}/start	Kitchen (bound), Manager	TICKET_ACTION	M	FR-KDS-03
K-04	POST /tickets/{id}/bump	Kitchen (bound), Manager	TICKET_ACTION	M	FR-KDS-03, 06
K-05	POST /tickets/{id}/recall	Kitchen (bound), Manager	TICKET_ACTION	M	FR-KDS-04

ID	Method and path	Roles	Class	Pri	SRS
K-06	POST /tickets/{id}/acknowledge-cancel	Kitchen (bound), Manager	TICKET_ACTION	M	FR-KDS-08
K-07	GET /kitchen/overview	Manager	READ	M	FR-KDS-09
B-01	GET /board	Public	BOARD_READ	M	FR-BRD-01
X-01	GET /stream/stations/{id}	Kitchen (bound), Manager	SSE_CONNECT	M	FR-KDS-05
X-02	GET /stream/manager	Manager	SSE_CONNECT	M	FR-KDS-09
X-03	GET /stream/board	Public	SSE_CONNECT	M	FR-BRD-02

4.6 Reports, audit and platform

ID	Method and path	Roles	Class	Pri	SRS
R-01	GET /reports/sales	Manager, Admin	REPORT	M	FR-RPT-01
R-02	GET /reports/top-items	Manager, Admin	REPORT	M	FR-RPT-02
R-03	GET /reports/prep-times	Manager, Admin	REPORT	M	FR-RPT-03
R-04	GET /reports/hourly	Manager, Admin	REPORT	S	FR-RPT-04
R-05	GET /reports/cancellations	Manager, Admin	REPORT	S	FR-RPT-05
AU-01	GET /audit	Manager, Admin	REPORT	M	FR-AUD-03
H-01	GET /actuator/health, /actuator/health/liveness, /actuator/health/readiness	Public	None	M	FR-SYS-05
H-02	GET /actuator/prometheus	Admin; internal port	None	M	FR-SYS-05
H-03	GET /v3/api-docs and the Swagger page	Dev and Compose profiles; Admin elsewhere	None	M	FR-SYS-02

5. Data types and schemas

5.1 Common types

Type	Definition
Id	Integer, 1 or more
Money	String of digits, a dot and exactly two decimals, for example 129.00; at most 10 integer digits. Signed money (price changes) allows a leading minus.
Rate	String with two decimals from 0.00 to 28.00
Instant	ISO 8601 UTC with milliseconds and Z
BusinessDay	Date, YYYY-MM-DD
Version	Integer, 0 or more
Role	CASHIER, KITCHEN, MANAGER, ADMIN
OrderType	DINE_IN, TAKEAWAY, DELIVERY
OrderStatus	CREATED, PAID, IN_KITCHEN, READY, COMPLETED, CANCELLED. PAID exists only inside the payment transaction; reads never return it (it appears in the audit log).
TicketStatus	NEW, IN_PROGRESS, DONE, CANCELLED
PaymentMethod	CASH, UPI, CARD
PaymentStatus	RECORDED, REFUND_PENDING, REFUNDED
SelectionType	SINGLE, MULTIPLE
CancelReason	Accepted from clients: CUSTOMER_CHANGED_MIND, WRONG_ORDER, ITEM_UNAVAILABLE, KITCHEN_ISSUE, PAYMENT_ISSUE, OTHER. UNPAID_TIMEOUT is written only by the system.
SlaColour	GREEN, AMBER, RED (BR-11)

5.2 Resource representations

Fields marked nullable are null when absent. All lists are arrays, empty when there is nothing to show.

User: id, username, role, active, stationIds (ids; empty unless role is KITCHEN), createdAt, version. The password hash is never returned.

Station: id, name, displayOrder, active.

Category: id, name, displayOrder, gstRate (Rate), active.

ModifierGroup: id, name, selectionType, minSelect, maxSelect, displayOrder, modifiers (list of Modifier).

Modifier: id, name, priceDelta (signed Money), active, displayOrder.

Item (admin view): id, categoryId, name, description (nullable), basePrice, targetPrepSeconds, active, available, trackStock, stockQuantity (null when not tracked), stationIds, modifierGroups, version.

MenuView (POS view): menuVersion; categories, each with id, name, gstRate and items; each item has id, name, description, price (Money), available, modifierGroups; combos (Should), each with id, name, price, available and components (itemId, name, quantity). Inactive items and categories are never included; unavailable items are included with available false.

Order: id, orderNumber, token, businessDay, orderType, status, rush, note (nullable), lines (list of OrderLine), subtotal, taxTotal, total, createdBy (id, username), createdAt, paidAt, readyAt, completedAt, cancelledAt (all nullable Instants), cancellation (nullable: reasonCode, reasonText, cancelledBy), tickets (list of id, stationId, status), version.

OrderSummary: id, orderNumber, token, orderType, status, rush, total, lineCount, createdAt, paidAt (nullable).

OrderLine: lineNo, itemId or comboId (one is null), name, unitPrice, modifiers (modifierId, name, priceDelta), modifierTotal, quantity, gstRate, lineSubtotal, lineTax, lineTotal, components (combo lines only: itemId, name, quantity). All names and prices are snapshots (BR-02).

Payment: id, orderId, method, amount, reference (nullable), tendered (nullable), changeDue (nullable), status, recordedBy (id, username), createdAt.

Bill: orderNumber, token, orderType, issuedAt, paid (boolean), lines (name, modifierNames, quantity, unitPrice, lineSubtotal), gst (list of rate, taxableAmount, tax), subtotal, taxTotal, total, paymentMethod (nullable), tendered (nullable), changeDue (nullable).

Refund: id, paymentId, orderId, amount, status (REFUND_PENDING or REFUNDED), reason, createdAt.

Ticket: id, orderId, orderNumber, token, stationId, orderType, rush, status, orderNote (nullable), items (orderLineId, itemId, name, quantity, modifierNames), targetSeconds, createdAt, startedAt, doneAt, cancelledAt, cancelAcknowledgedAt (nullable Instants), recallCount, ageSeconds, percentOfTarget, colour, version. ageSeconds runs from createdAt to the snapshot or event time (to doneAt for DONE tickets); percentOfTarget and colour follow BR-11 at that moment.

StockEntry: itemId, name, quantity, available, version, updatedAt. **StockAdjustment:** id, itemId, delta, reason, actor (id, username), createdAt.

AuditEvent: id, occurredAt, actorId (nullable), actorRole, entityType, entityId, action, fromState, toState, reason (nullable), correlationId, details (nullable object).

6. Authentication and users

Case tables list status, code and notes; "field" means an entry in errors[] of a VALIDATION_FAILED response.

6.1 A-01 POST /auth/login

Request: username (string, 1 to 50 characters) and password (string, 1 to 128 bytes), both required. Response 200 returns the access token and the user; with refresh tokens enabled it also sets the kf_refresh cookie.

```
{
  "accessToken": "eyJhbGciOiJIUzI1NiJ9...",
  "tokenType": "Bearer",
  "expiresIn": 900,
  "user": { "id": 3, "username": "cashier1", "role": "CASHIER", "stationIds":
[] }
}
```

Case	Status	Code	Notes
Valid credentials	200	None	Resets the failed-attempt counter
Wrong username or wrong password	401	UNAUTHENTICATED	One message for both, and similar response time
Deactivated user	401	UNAUTHENTICATED	Same message as a wrong password, so status is not revealed
5 failures within 10 minutes	429	RATE_LIMITED	Locked for 15 minutes even with the correct password; Retry-After set (FR-AUTH-06). Unknown usernames are throttled the same way, so lockout never reveals which names exist
LOGIN bucket exhausted for the address and username	429	RATE_LIMITED	Retry-After set
Missing or blank username or password	422	VALIDATION_FAILED	Field code REQUIRED
Username above 50 characters or password above 128 bytes	422	VALIDATION_FAILED	Field code TOO_LONG; bounds the hashing work
Body not JSON, or wrong Content-Type	400, 415	MALFORMED_REQUEST, UNSUPPORTED_MEDIA_TYPE	

6.2 A-02 POST /auth/refresh (Should)

No body; the kf_refresh cookie identifies the session. Response 200 is the same as login and the cookie is rotated.

Case	Status	Code	Notes
Valid cookie	200	None	New access token, new cookie; the old token is consumed
No cookie	401	UNAUTHENTICATED	
Expired or unknown token	401	UNAUTHENTICATED	Cookie cleared
Consumed token presented again	401	UNAUTHENTICATED	The whole token family is revoked and a security event is logged (FR-AUTH-07). A 10-second grace window after consumption returns 401 without revoking, so two tabs refreshing together do not log the user out
User deactivated since login	401	UNAUTHENTICATED	Cookie cleared
Origin header missing or not on the allow-list	403	FORBIDDEN	Protects the cookie endpoint
Body present	Ignored	None	

6.3 A-03 POST /auth/logout and A-04 GET /auth/me

Logout revokes the token family and clears the cookie; it returns 204 even when there is no cookie, so repeating it is safe. The access token cannot be revoked and expires on its own. GET /auth/me returns the User plus tokenExpiresAt; any invalid token returns 401.

6.4 A-05 POST /auth/change-password (proposed)

Request: currentPassword and newPassword. Response 204. All refresh tokens of the user are revoked; the current access token lives on until it expires.

Case	Status	Code	Notes
Valid change	204	None	
currentPassword wrong	422	VALIDATION_FAILED	Field currentPassword, code INCORRECT_PASSWORD (not 401: the user is authenticated). Counts toward the LOGIN bucket
newPassword shorter than 8 or longer than 72 bytes	422	VALIDATION_FAILED	TOO_SHORT or TOO_LONG; 72 bytes is the BCrypt limit
newPassword equals currentPassword, equals the username, or is on the common-password list	422	VALIDATION_FAILED	WEAK_PASSWORD

6.5 U-01 to U-05 Users (Admin)

U-01 GET /admin/users. Filters: role, active, q (username prefix, 1 to 50 characters). Sort: username (default, ascending) or createdAt. Paged list of User.

U-02 POST /admin/users. Request fields:

Field	Rules
username	Required, 3 to 50 characters from lowercase letters, digits, dot, underscore, hyphen; unique case-insensitively
password	Required, 8 to 72 bytes, not equal to the username, not on the common-password list
role	Required, one of the four roles
stationIds	Required and non-empty for KITCHEN; not allowed for other roles; each must be an active station
active	Optional, default true

Response 201 with the User and a Location header.

Case	Status	Code and field code
Username taken	422	VALIDATION_FAILED, DUPLICATE_VALUE
Username pattern or length wrong	422	VALIDATION_FAILED, INVALID_FORMAT, TOO_SHORT or TOO_LONG
Weak or out-of-length password	422	VALIDATION_FAILED, WEAK_PASSWORD, TOO_SHORT or TOO_LONG
Role not one of the four	422	VALIDATION_FAILED, INVALID_ENUM
KITCHEN without stations	422	VALIDATION_FAILED, REQUIRED on stationIds
Stations given for a non-kitchen role	422	VALIDATION_FAILED, NOT_APPLICABLE
Unknown or inactive station	422	VALIDATION_FAILED, UNKNOWN_ID or STATION_INACTIVE

U-03 GET /admin/users/{id} returns the User or 404.

U-04 PATCH /admin/users/{id}. Optional fields role, active and stationIds, plus required expectedVersion; at least one field besides expectedVersion. The username cannot change (unknown property, 400).

Case	Status	Code and notes
Success	200	The updated User; deactivation also revokes the user's refresh tokens at once
No field to change	422	VALIDATION_FAILED, ONE_OF_REQUIRED
Version out of date	409	STALE_VERSION
Admin deactivates or demotes themselves	422	VALIDATION_FAILED, SELF_LOCKOUT
Change would leave no active admin	422	VALIDATION_FAILED, LAST_ADMIN
Role changed to KITCHEN without stationIds	422	VALIDATION_FAILED, REQUIRED
Role changed away from KITCHEN	200	Station bindings are cleared automatically

Case	Status	Code and notes
Deactivated user's open session	200	Access token and open streams end within 15 minutes (FR-AUTH-05)
Unknown id	404	NOT_FOUND

U-05 POST /admin/users/{id}/password-reset (proposed). Request newPassword, same rules as U-02. Response 204; revokes refresh tokens and clears any lockout. Unknown id returns 404, a weak password 422 WEAK_PASSWORD.

7. Reference data, configuration and menu

Small reference lists (stations, categories, configuration) are returned whole as an object with a content array and no page object.

7.1 S-01 to S-03 Stations

S-01 GET /stations. Returns active stations in display order. includeInactive=true is allowed for Admin only; for other roles it returns 403.

S-02 POST /admin/stations. name (1 to 40 characters, unique, compared exactly after trimming) and displayOrder (0 to 1000, default 0). Response 201.

S-03 PATCH /admin/stations/{id}. Optional name, displayOrder, active. Stations carry no version, so the last write wins.

Case	Status	Code and notes
Duplicate name	422	VALIDATION_FAILED, DUPLICATE_VALUE
Deactivate a station that has open tickets	409	RESOURCE_IN_USE, references: tickets
Deactivate the only station of an active item	422	VALIDATION_FAILED, LAST_STATION_FOR_ITEM; the message names up to 10 items
Reactivate a station	200	Allowed
Kitchen user bound to an inactive station	200	Login still works; the station queue is empty

Case	Status	Code and notes
Unknown id	404	NOT_FOUND

7.2 C-01 and C-02 Configuration

C-01 GET /admin/config returns every key with its value, allowed range, default, updatedAt and updatedBy. **C-02 PATCH /admin/config** takes an object values with key-to-string pairs, applied atomically (all or none), takes effect for new operations at once (cache evicted after commit, CONFIG_CHANGED pushed to stations), and is audited as one change. Configuration has no version; the last write wins.

Key	Allowed values	Default	Governs
recall_window_seconds	Integer 0 to 3600	600	BR-17
unpaid_timeout_minutes	Integer 1 to 120	15	FR-ORD-12
business_day_cutoff	HH:mm from 00:00 to 08:00	04:00	BR-16
sla_amber_percent	Integer 1 to 99	80	BR-11
sla_red_percent	Integer 2 to 300, above the amber value	100	BR-11
board_ready_highlight_minutes	Integer 1 to 60	5	FR-BRD-04

Case	Status	Code and notes
Unknown key	422	VALIDATION_FAILED, UNKNOWN_KEY on values.<key>
Value outside its range or not parseable	422	VALIDATION_FAILED, OUT_OF_RANGE or INVALID_FORMAT
Amber not below red (counting values already stored)	422	VALIDATION_FAILED, INVALID_RANGE

Case	Status	Code and notes
Change business_day_cutoff while any order is CREATED, IN_KITCHEN or READY	409	RESOURCE_IN_USE, references: open orders. Prevents token numbers restarting in the middle of service
Empty values object	422	VALIDATION_FAILED, REQUIRED

7.3 M-01 GET /menu

Query: categoryId, q (1 to 40 characters, case-insensitive name match), includeUnavailable (default true). Response: MenuView. The ETag combines the menu version with a hash of the filters.

Case	Status	Notes
First request	200	Body plus ETag
If-None-Match equals the current ETag	304	No body
Menu changed since	200	New ETag
categoryId matches nothing, or an empty menu	200	Empty categories
q blank after trimming	422	VALIDATION_FAILED, INVALID_FORMAT
Items marked unavailable	200	Present with available false, so screens can show them disabled (BR-04)
Price or availability changed between this read and an order	n/a	Order totals come from the server at order time; clients show the server's totals

7.4 Categories (M-02 to M-04)

M-02 GET /admin/categories returns all categories; includeInactive defaults to true. **M-03 POST** takes name (1 to 60, unique), displayOrder (0 to 1000), gstRate (0.00 to 28.00) and active (default true). **M-04 PATCH** changes name, displayOrder, gstRate or active; categories carry no version.

Case	Status	Code and field code
Duplicate name	422	VALIDATION_FAILED, DUPLICATE_VALUE
gstRate outside 0 to 28, or not two decimals	422	VALIDATION_FAILED, OUT_OF_RANGE or INVALID_SCALE
Deactivate a category that still has active items	409	RESOURCE_IN_USE, references: items
Change gstRate	200	Applies to orders created afterwards; existing orders keep their snapshot

7.5 Items (M-05 to M-10)

M-05 GET /admin/items. Filters categoryId, active, available, trackStock, q. Sort name (default), basePrice or createdAt. Paged list of Item.

M-06 POST /admin/items. Fields:

Field	Rules
categoryId	Required, an active category
name	Required, 1 to 80 characters, unique case-insensitively
description	Optional, up to 300 characters
basePrice	Required, above 0.00, two decimals
targetPrepSeconds	Required, 1 to 7200
stationIds	Required, 1 to 10 distinct active stations (BR-09)
trackStock	Optional, default false
initialStock	Required, 0 to 100000, when trackStock is true; not allowed otherwise
active	Optional, default true

The item starts available. Response 201.

M-07 GET /admin/items/{id} returns the Item or 404.

M-08 PATCH /admin/items/{id}. Optional categoryId, name, description, basePrice, targetPrepSeconds, active, trackStock (with initialStock when switching it on); expectedVersion required. Availability and stations are not accepted here (use M-17 and M-10); sending them is an unknown property, 400.

M-09 DELETE /admin/items/{id}. Removes the item together with its station links, modifier groups, modifiers and stock row, in one transaction. Response 204.

M-10 PUT /admin/items/{id}/stations. Replaces the station set: stationIds (1 to 10 distinct active stations) and expectedVersion. Applies to orders created afterwards; open tickets keep their station.

Case	Status	Code and field code
Item name taken	422	VALIDATION_FAILED, DUPLICATE_VALUE
Price zero or negative; not two decimals	422	VALIDATION_FAILED, OUT_OF_RANGE, INVALID_SCALE
targetPrepSeconds outside 1 to 7200	422	VALIDATION_FAILED, OUT_OF_RANGE
Category unknown or inactive	422	VALIDATION_FAILED, UNKNOWN_ID or ITEM_INACTIVE
No station, or an unknown or inactive one	422	VALIDATION_FAILED, TOO_FEW, UNKNOWN_ID, STATION_INACTIVE
trackStock true without initialStock; initialStock when not tracking	422	VALIDATION_FAILED, REQUIRED, NOT_APPLICABLE
Version out of date (M-08, M-10)	409	STALE_VERSION
Price changed	200	Applies to new orders only (FR-MENU-08)
Item deactivated	200	Leaves the POS menu; open orders unaffected
Delete an item that was ever ordered, used in a combo, or has stock history	409	RESOURCE_IN_USE, references by type and count (FR-MENU-05). Deactivate instead
Delete an unused item	204	
Unknown id	404	NOT_FOUND

7.6 Modifier groups and modifiers (M-11 to M-16)

M-11 POST /admin/items/{id}/modifier-groups. name (1 to 60, unique within the item), selectionType, minSelect (0 to 10), maxSelect (1 to 10), displayOrder, and optionally an inline modifiers list of name and priceDelta. **M-12 PATCH** changes the same fields. **M-13 DELETE** removes a group.

M-14 POST /admin/modifier-groups/{id}/modifiers. name (1 to 60, unique within the group), priceDelta (signed money, never below minus the item's base price, so no line can become negative), active (default true), displayOrder. **M-15 PATCH** and **M-16 DELETE** act

on one modifier. Groups and modifiers carry no version; any change increments the menu version and applies to orders created afterwards.

Case	Status	Code and field code
SINGLE group with maxSelect other than 1	422	VALIDATION_FAILED, OUT_OF_RANGE on maxSelect
maxSelect below minSelect	422	VALIDATION_FAILED, INVALID_RANGE
minSelect above the number of active modifiers (on create, or when deactivating or deleting one)	422	VALIDATION_FAILED, MIN_EXCEEDS_OPTIONS
Duplicate group or modifier name	422	VALIDATION_FAILED, DUPLICATE_VALUE
priceDelta below minus the base price	422	VALIDATION_FAILED, OUT_OF_RANGE
Delete a group or modifier already used on an order	409	RESOURCE_IN_USE; deactivate the modifier instead
Parent item, group or modifier unknown	404	NOT_FOUND

7.7 M-17 PATCH /items/{id}/availability

Roles Manager and Admin. Request: available (boolean) and an optional expectedVersion. Response 200 with id, available and version. Effective for new orders as soon as the transaction commits; the menu cache is evicted and the ETag changes.

Case	Status	Code and notes
Change applied	200	Audited
Already in the requested state	200	No change, no audit record, version unchanged (safe to repeat)
Item is inactive	422	VALIDATION_FAILED, ITEM_INACTIVE
Setting available true on a tracked item with stock 0	422	VALIDATION_FAILED, STOCK_ZERO
expectedVersion given and stale	409	STALE_VERSION

Case	Status	Code and notes
Order created at the same moment	n/a	The order sees whichever state it reads inside its transaction; an order already committed stands
Role Cashier or Kitchen	403	FORBIDDEN

7.8 Combos (M-18 to M-21, Should)

A Combo has id, categoryId, name, price, active, available (true when every component is active and available), and components (itemId, name, quantity).

M-18 GET /admin/combos lists them. **M-19 POST** takes categoryId, name (1 to 80, unique), price (above 0.00) and components (1 to 10 distinct items, quantity 1 to 10 each). **M-20 PATCH** changes any of those fields; components, when sent, replace the set. **M-21 DELETE** returns 204.

Case	Status	Code and field code
Component item unknown or inactive	422	VALIDATION_FAILED, UNKNOWN_ID or ITEM_INACTIVE
Same item twice	422	VALIDATION_FAILED, DUPLICATE_VALUE
Fewer than one or more than ten components	422	VALIDATION_FAILED, TOO_FEW or TOO_MANY
Delete a combo that was ordered	409	RESOURCE_IN_USE; deactivate instead
Modifiers on a combo	n/a	Not supported in version 1; combo lines accept no modifierIds

8. Inventory (Should)

I-01 GET /stock. Lists tracked items as StockEntry. Filters maxQuantity (integer 0 or more, for low-stock views) and q. Sort name or quantity (default, ascending).

I-02 POST /items/{id}/stock-adjustments. Request: delta (non-zero integer from minus 100000 to 100000), reason (1 to 200 characters, required) and an optional expectedVersion. Response 201 with the adjustment and the new StockEntry.

I-03 GET /items/{id}/stock-adjustments. Paged history, newest first.

Case	Status	Code and field code
Adjustment applied	201	Audited with its reason
delta is 0 or outside the range	422	VALIDATION_FAILED, OUT_OF_RANGE
reason missing or blank	422	VALIDATION_FAILED, REQUIRED
Item does not track stock	422	VALIDATION_FAILED, NOT_TRACKED
Result would be below zero	422	VALIDATION_FAILED, NEGATIVE_STOCK
expectedVersion stale	409	STALE_VERSION
Stock rises from 0	201	The item becomes available again (FR-INV-03)
Stock falls to 0	201	The item becomes unavailable
Adjustment and an order at the same moment	n/a	Serialised by the conditional update; stock never goes below zero
Unknown item	404	NOT_FOUND

Automatic stock movements: an order reserves stock when created; stock is restored when an order is cancelled while CREATED or cancelled by the unpaid timeout; cancelling an IN_KITCHEN order does not restore stock (BR-12).

9. Orders

How the order lifecycle (SRS section 6.1) maps to endpoints:

Transition	Endpoint	Who
(none) to CREATED	O-01 POST /orders	Cashier, Manager
CREATED to IN_KITCHEN (through the transient PAID)	P-01 POST /orders/{id}/payments	Cashier, Manager
IN_KITCHEN to READY	K-04 POST /tickets/{id}/bump, when the last ticket is done	System

Transition	Endpoint	Who
READY back to IN_KITCHEN	K-05 POST /tickets/{id}/recall	Kitchen (bound), Manager
READY to COMPLETED	O-06 POST /orders/{id}/complete	Cashier, Manager
CREATED or IN_KITCHEN to CANCELLED	O-05 POST /orders/{id}/cancel	Cashier (CREATED only), Manager
CREATED to CANCELLED by timeout	Scheduled job (FR-ORD-12)	System

9.1 O-01 POST /orders

Request fields:

Field	Rules
orderType	Required: DINE_IN, TAKEAWAY or DELIVERY
note	Optional, up to 200 characters, no control characters
lines	Required, 1 to 30 lines (the 30-line limit is proposed)
lines[].itemId or lines[].comboId	Exactly one of the two
lines[].quantity	Required integer, 1 to 50
lines[].modifierIds	Optional, up to 20 distinct ids; not allowed on a combo line

Clients never send prices, totals, token, status or any other computed value; all of them are unknown properties and return 400. The Idempotency-Key header is recommended (section 2.7).

```
{
  "orderType": "TAKEAWAY",
  "note": "Pack the burgers separately",
  "lines": [
    { "itemId": 4, "quantity": 2, "modifierIds": [212, 215] },
    { "itemId": 20, "quantity": 1, "modifierIds": [341] }
  ]
}
```

Response 201 with Location: /api/v1/orders/1042 and the full Order. The arithmetic follows BR-03: line 1 is (169.00 + 20.00) x 2 = 378.00 with 5.00 percent GST of 18.90; line 2 is (69.00 + 30.00) x 1 = 99.00 with 18.00 percent GST of 17.82.

```
{
  "id": 1042,
  "orderNumber": "KF-20261030-0017",
  "token": 17,
  "businessDay": "2026-10-30",
  "orderType": "TAKEAWAY",
  "status": "CREATED",
  "rush": false,
  "note": "Pack the burgers separately",
  "lines": [
    {
      "lineNo": 1, "itemId": 4, "comboId": null, "name": "Spicy Chicken
Burger",
      "unitPrice": "169.00",
      "modifiers": [
        { "modifierId": 212, "name": "Hot", "priceDelta": "0.00" },
        { "modifierId": 215, "name": "Extra cheese", "priceDelta": "20.00" }
      ],
      "modifierTotal": "20.00", "quantity": 2, "gstRate": "5.00",
      "lineSubtotal": "378.00", "lineTax": "18.90", "lineTotal": "396.90",
"components": []
    },
    {
      "lineNo": 2, "itemId": 20, "comboId": null, "name": "Cola",
"unitPrice": "69.00",
      "modifiers": [ { "modifierId": 341, "name": "Large", "priceDelta":
"30.00" } ],
      "modifierTotal": "30.00", "quantity": 1, "gstRate": "18.00",
      "lineSubtotal": "99.00", "lineTax": "17.82", "lineTotal": "116.82",
```

```
"components": []
    }
  ],
  "subtotal": "477.00", "taxTotal": "36.72", "total": "513.72",
  "createdBy": { "id": 3, "username": "cashier1" },
  "createdAt": "2026-10-30T09:15:30.123Z",
  "paidAt": null, "readyAt": null, "completedAt": null, "cancelledAt": null,
  "cancellation": null, "tickets": [], "version": 0
}
```


How errors are reported. All field violations (check step 7) are collected and returned together. When every violation is an item-availability problem, the top-level code is ITEM_UNAVAILABLE (FR-MENU-04); when there is any other violation as well, it is VALIDATION_FAILED. Either way errors[] lists each one with its own field code. Stock and other business rules (step 9) are checked only when validation passed, so a request with field errors never reaches the stock check.

Case	Status	Code and field code
Valid request	201	Token and order number assigned; stock reserved; audited
orderType missing or not allowed	422	VALIDATION_FAILED, REQUIRED or INVALID_ENUM
note above 200 characters, or control characters	422	VALIDATION_FAILED, TOO_LONG or INVALID_CHARACTERS
lines missing, empty, or above 30	422	VALIDATION_FAILED, TOO_FEW or TOO_MANY
A line with neither or both of itemId and comboId	422	VALIDATION_FAILED, ONE_OF_REQUIRED
quantity missing, below 1 or above 50	422	VALIDATION_FAILED, REQUIRED or OUT_OF_RANGE
quantity not an integer, for example 2.5	400	MALFORMED_REQUEST
itemId or comboId unknown	422	VALIDATION_FAILED, UNKNOWN_ID

Case	Status	Code and field code
Item or combo inactive or unavailable	422	ITEM_UNAVAILABLE (or VALIDATION_FAILED when mixed), field code ITEM_UNAVAILABLE
modifierIds on a combo line	422	VALIDATION_FAILED, NOT_APPLICABLE
Modifier unknown; not belonging to the item; inactive; repeated	422	VALIDATION_FAILED, UNKNOWN_ID; MODIFIER_NOT_ALLOWED; MODIFIER_UNAVAILABLE; DUPLICATE_VALUE
Fewer selections than the group minimum	422	VALIDATION_FAILED, MODIFIER_MIN (the message names the group)
More than the group maximum, or two choices in a SINGLE group	422	VALIDATION_FAILED, MODIFIER_MAX
Price, total, token or status in the body	400	MALFORMED_REQUEST (unknown property)
Not enough stock for a tracked item	409	OUT_OF_STOCK with details.items (every short item at that moment); nothing is reserved and nothing is created
Idempotency-Key malformed	422	VALIDATION_FAILED, INVALID_FORMAT
Key replayed with the same payload	201	The original body, with Idempotency-Replayed: true
Key reused with a different payload	422	IDEMPOTENCY_KEY_REUSED
Role Kitchen or Admin; no token	403; 401	FORBIDDEN; UNAUTHENTICATED
ORDER_WRITE bucket exhausted	429	RATE_LIMITED
Pool exhausted or lock timeout	503	SERVICE_BUSY, Retry-After; nothing created; retrying with the same key is safe
Created just before or after the business-day cutoff (04:00 Asia/Kolkata)	201	Different businessDay; the token restarts at 1
More than 9,999 orders in one business day	201	The order number grows to five digits; the token keeps counting

Case	Status	Code and field code
Menu or prices changed since the client's last GET /menu	201	Priced at the current database prices; clients show the response's totals
An item is deactivated after the order was created	n/a	The order stands and can still be paid (snapshots); only create and edit check availability

9.2 O-02 GET /orders

Parameter	Rules
status	Comma-separated OrderStatus values, at most 10
open	Boolean shortcut for CREATED, IN_KITCHEN and READY; cannot be combined with status
orderType, rush	Exact match
businessDay	A date; cannot be combined with createdFrom or createdTo
createdFrom, createdTo	Instants; the range must not exceed 92 days
token	Integer; searched in the given business day, or the current one
orderNumber	Exact order number, format KF-YYYYMMDD-NNNN
page, size, sort, cursor	Section 2.6. Sort: createdAt (default, descending), token, total. Cursor mode is newest first

With none of businessDay, createdFrom, createdTo or orderNumber, the current business day is used. Response: a paged list of OrderSummary.

Case	Status	Code and field code
Default call	200	Current business day, newest first
Invalid status or orderType value; more than 10 statuses	422	VALIDATION_FAILED, INVALID_ENUM or TOO_MANY

Case	Status	Code and field code
open together with status	422	VALIDATION_FAILED, NOT_APPLICABLE
businessDay together with createdFrom or createdTo	422	VALIDATION_FAILED, NOT_APPLICABLE
createdFrom after createdTo, or a range above 92 days	422	VALIDATION_FAILED, INVALID_RANGE
orderNumber with a wrong format	422	VALIDATION_FAILED, INVALID_FORMAT
orderNumber, token or filters that match nothing	200	Empty content, never 404
Dates in the future	200	Empty content
Role Kitchen or Admin	403	FORBIDDEN

Target: p95 under 300 ms with 100,000 orders (NFR-PERF-03).

9.3 O-03 GET /orders/{id} and O-08 GET /orders/{id}/tickets

O-03 returns the full Order, including its tickets summary; unknown id returns 404. O-08 returns an object with a content array of full Ticket representations. Both are open to every Cashier and Manager, not only to the person who created the order.

9.4 O-04 PUT /orders/{id}

Replaces orderType, note and all lines of an order that is still CREATED. The body has the fields of O-01 plus a required expectedVersion. Every line is re-priced at current prices and stock reservations are adjusted by the difference (FR-ORD-06). Token, order number and business day never change. Response 200 with the Order and its new version.

Case	Status	Code and notes
Edit applied	200	Totals recalculated; audited
Identical content	200	No new version and no audit record
Status is not CREATED (paid, in kitchen, ready, completed)	409	INVALID_TRANSITION with details.currentStatus; requestedOperation EDIT

Case	Status	Code and notes
Order was cancelled meanwhile, for example by the unpaid timeout	409	INVALID_TRANSITION, currentStatus CANCELLED
expectedVersion stale	409	STALE_VERSION
A kept item has become unavailable since the order was created	422	ITEM_UNAVAILABLE; it cannot stay on the order
Increased quantity needs stock that is not there	409	OUT_OF_STOCK; the original reservation is kept
Any field violation of O-01	422	Same codes as O-01
Edit and payment at the same moment	n/a	Whoever locks the order first wins: an edit after payment gets 409; a payment sent with the old amount after an edit gets 422 AMOUNT_MISMATCH

9.5 O-05 POST /orders/{id}/cancel

Request: reasonCode (a CancelReason accepted from clients), reasonText (up to 200 characters; required when reasonCode is OTHER) and an optional expectedVersion. Response 200 with the Order.

Order status	Cashier	Manager
CREATED	Allowed	Allowed
IN_KITCHEN	403 FORBIDDEN	Allowed
READY, COMPLETED	409 INVALID_TRANSITION	409 INVALID_TRANSITION
CANCELLED	409 INVALID_TRANSITION	409 INVALID_TRANSITION

The 403 for a Cashier on an IN_KITCHEN order depends on the order's state, so it is raised after the state is read, inside the transaction. A second cancel returns 409 with details.currentStatus CANCELLED; clients treat that as success.

Effects: open tickets become CANCELLED and stations show a notice (FR-KDS-08); stock is restored when the order was CREATED and is not when it was IN_KITCHEN (wastage, BR-12); cancelling a paid IN_KITCHEN order creates a REFUND_PENDING refund

(Should); the token leaves the status board; all changes are audited.

Case	Status	Code and field code
reasonCode missing	422	VALIDATION_FAILED, REQUIRED
reasonCode not allowed, including UNPAID_TIMEOUT	422	VALIDATION_FAILED, INVALID_ENUM
OTHER without reasonText	422	VALIDATION_FAILED, REQUIRED on reasonText
reasonText above 200 characters	422	VALIDATION_FAILED, TOO_LONG
expectedVersion stale	409	STALE_VERSION
Cancel and payment at the same moment	n/a	Whoever locks the order first wins; the loser gets 409
Unknown order	404	NOT_FOUND

9.6 O-06 POST /orders/{id}/complete and O-07 PATCH /orders/{id}/rush

O-06 has no body (expectedVersion optional) and moves a READY order to COMPLETED; the token leaves the status board. Response 200 with the Order.

Case	Status	Code and notes
Order is READY	200	Audited
CREATED, IN_KITCHEN or CANCELLED	409	INVALID_TRANSITION
Already COMPLETED	409	INVALID_TRANSITION with currentStatus COMPLETED; treat as success
Role Kitchen or Admin	403	FORBIDDEN

O-07 (Manager) takes rush (boolean) and expectedVersion. It is allowed while the order is CREATED or IN_KITCHEN, updates the rush flag of every open ticket in the same transaction and pushes TICKET_CHANGED to each station. READY, COMPLETED and

CANCELLED orders return 409 INVALID_TRANSITION. Setting the value it already has returns 200 with no change and no audit record. A stale expectedVersion returns 409 STALE_VERSION. Response 200 with the Order.

10. Payments and bills

10.1 P-01 POST /orders/{id}/payments

Request: method (CASH, UPI or CARD), amount (Money, must equal the order total, BR-08), reference (optional, up to 64 characters of letters, digits, space, hyphen, underscore, slash) and tendered (CASH only, Money).

```
{ "method": "UPI", "amount": "513.72", "reference": "UPI-8831904412" }
```

Response 201: the Payment and an order object with id, orderNumber, token, status, version, paidAt and tickets (one per active station involved). In one transaction the order moves through PAID to IN_KITCHEN and the tickets are created (FR-PAY-02); events are pushed after commit.

```
{
  "payment": {
    "id": 981, "orderId": 1042, "method": "UPI", "amount": "513.72",
    "reference": "UPI-8831904412", "tendered": null, "changeDue": null,
    "status": "RECORDED", "recordedBy": { "id": 3, "username": "cashier1" },
    "createdAt": "2026-10-30T09:16:12.004Z"
  },
  "order": {
    "id": 1042, "orderNumber": "KF-20261030-0017", "token": 17, "status":
"IN_KITCHEN",
    "version": 2, "paidAt": "2026-10-30T09:16:12.004Z",
    "tickets": [
      { "id": 5521, "stationId": 1, "status": "NEW" },
      { "id": 5522, "stationId": 3, "status": "NEW" },
      { "id": 5523, "stationId": 4, "status": "NEW" }
    ]
  }
}
```

For a cash payment with tendered 600.00 the payment carries tendered 600.00 and changeDue 86.28.

Case	Status	Code and field code
Valid payment	201	Tickets created; order IN_KITCHEN; audit records written
amount differs from the order total	422	AMOUNT_MISMATCH with details.expectedAmount
amount not two decimals; zero or negative	422	VALIDATION_FAILED, INVALID_SCALE or OUT_OF_RANGE
amount sent as a JSON number	400	MALFORMED_REQUEST
method missing or not allowed	422	VALIDATION_FAILED, REQUIRED or INVALID_ENUM
reference above 64 characters or with other characters	422	VALIDATION_FAILED, TOO_LONG or INVALID_CHARACTERS
tendered with UPI or CARD	422	VALIDATION_FAILED, NOT_APPLICABLE
tendered below the amount	422	VALIDATION_FAILED, OUT_OF_RANGE
Unknown order	404	NOT_FOUND
Order already paid (PAID, IN_KITCHEN, READY, COMPLETED)	409	PAYMENT_ALREADY_RECORDED
Order CANCELLED, including by the unpaid timeout	409	INVALID_TRANSITION, currentStatus CANCELLED
Two payment requests at the same moment	n/a	One 201 and one 409 PAYMENT_ALREADY_RECORDED (FR-PAY-03)
Payment and cancel at the same moment	n/a	Whoever locks the order first wins; the loser gets 409
Payment sent with the amount from before another terminal edited the order	422	AMOUNT_MISMATCH with the current total; re-read the order
An ordered item has become unavailable or inactive since the order was created	201	The order stands; availability is checked only on create and edit

Case	Status	Code and field code
An item's station has been deactivated	201	Tickets are created only for active stations; an item always keeps at least one (LAST_STATION_FOR_ITEM)
Failure while creating tickets	500 or 503	Nothing is stored: the order stays CREATED and has no payment; retrying is safe
The client timed out and does not know the outcome	n/a	Call P-02: 200 means it succeeded, 404 means retry
Role Kitchen or Admin	403	FORBIDDEN
Idempotency-Key header sent	n/a	Ignored; protection comes from the state check

10.2 P-02 GET /orders/{id}/payment

Returns the Payment. An unknown order, or an order with no payment yet, returns 404 NOT_FOUND.

10.3 P-03 GET /orders/{id}/bill

Returns the Bill (FR-PAY-05). Unit prices include the selected modifiers; GST is grouped by rate. An unpaid order returns a provisional bill with paid false and no payment fields, so the cashier can show the total before taking payment. A cancelled order returns 409 INVALID_TRANSITION; there is no bill for it.

```
{
  "orderNumber": "KF-20261030-0017", "token": 17, "orderType": "TAKEAWAY",
  "issuedAt": "2026-10-30T09:16:12.004Z", "paid": true,
  "lines": [
    { "name": "Spicy Chicken Burger", "modifierNames": ["Hot", "Extra
cheese"],
      "quantity": 2, "unitPrice": "189.00", "lineSubtotal": "378.00" },
    { "name": "Cola", "modifierNames": ["Large"],
      "quantity": 1, "unitPrice": "99.00", "lineSubtotal": "99.00" }
  ],
  "gst": [
    { "rate": "5.00", "taxableAmount": "378.00", "tax": "18.90" },
    { "rate": "18.00", "taxableAmount": "99.00", "tax": "17.82" }
  ],
  "subtotal": "477.00", "taxTotal": "36.72", "total": "513.72",
  "paymentMethod": "UPI", "tendered": null, "changeDue": null
}
```

The GST rows must add up to taxTotal and the lines to subtotal; a contract test checks both for every bill in the test data.

10.4 P-04 GET /orders/{id}/bill.pdf (Could)

Returns the same bill as application/pdf with Content-Disposition inline. The totals must equal the JSON bill. The unpaid and cancelled rules are the same as P-03. If an Accept header excludes application/pdf the response is 406 NOT_ACCEPTABLE.

10.5 P-05 GET /refunds and P-06 POST /refunds/{id}/complete (Should)

Refunds are created automatically when a paid order is cancelled; no endpoint creates one. **P-05** (Manager) lists Refund records with filters status (REFUND_PENDING or REFUNDED), orderId, and from and to (business days, within 92 days); sort createdAt descending. **P-06** (Manager, proposed) takes no body and sets the refund to REFUNDED, which also sets the payment status to REFUNDED in the same transaction.

Case	Status	Code and notes
Refund completed	200	The Refund with status REFUNDED
Already REFUNDED	409	INVALID_TRANSITION, currentStatus REFUNDED; treat as success

Case	Status	Code and notes
Unknown refund	404	NOT_FOUND
Invalid status filter value	422	VALIDATION_FAILED, INVALID_ENUM
Role other than Manager	403	FORBIDDEN

11. Kitchen

11.1 K-01 GET /stations/{id}/tickets

The live queue of one station for Kitchen users bound to it and for Managers. Response: serverTime, the sla thresholds, the station, tickets (NEW and IN_PROGRESS, rush first and then oldest, BR-10) and cancelledNotices (cancelled tickets not yet acknowledged, newest first). A screen uses this as its snapshot on connect and reconnect.


```
{
  "serverTime": "2026-10-30T09:20:00.000Z",
  "sla": { "amberPercent": 80, "redPercent": 100 },
  "station": { "id": 1, "name": "Fry" },
  "tickets": [
    {
      "id": 5521, "orderId": 1042, "orderNumber": "KF-20261030-0017",
"token": 17,
      "stationId": 1, "orderType": "TAKEAWAY", "rush": false, "status":
"NEW",
      "orderNote": "Pack the burgers separately",
      "items": [
        { "orderLineId": 7301, "itemId": 4, "name": "Spicy Chicken Burger",
          "quantity": 2, "modifierNames": ["Hot", "Extra cheese"] }
      ],
      "targetSeconds": 300, "createdAt": "2026-10-30T09:16:12.004Z",
      "startedAt": null, "doneAt": null, "cancelledAt": null,
"cancelAcknowledgedAt": null,
      "recallCount": 0, "ageSeconds": 228, "percentOfTarget": 76, "colour":
"GREEN", "version": 0
    }
  ],
  "cancelledNotices": []
}
```

Case	Status	Notes
Valid call	200	Empty arrays when there is nothing open
Unknown station	404	NOT_FOUND
Kitchen user not bound to this station	403	FORBIDDEN (FR-AUTH-04)
Inactive station	200	Empty lists
Role Cashier or Admin	403	FORBIDDEN

K-02 GET /tickets/{id} returns one Ticket with the same access rules; unknown id returns 404.

11.2 K-03 to K-06 Ticket actions

All four use class TICKET_ACTION and are open to Kitchen users bound to the ticket's station and to Managers. K-03, K-04 and K-05 require expectedVersion in the body; K-06 accepts it optionally. After commit each action pushes TICKET_CHANGED to the station and manager streams.

ID	Action	Moves	Response 200
K-03	POST /tickets/{id}/start	NEW to IN_PROGRESS, sets startedAt	The Ticket
K-04	POST /tickets/{id}/bump	IN_PROGRESS to DONE, sets doneAt	ticket (Ticket) and order (id, status, version, becameReady)
K-05	POST /tickets/{id}/recall	DONE to IN_PROGRESS, clears doneAt, adds 1 to recallCount	ticket and order (id, status, version)
K-06	POST /tickets/{id}/acknowledge-cancel	Sets cancelAcknowledgedAt on a CANCELLED ticket	The Ticket

The response to a bump that completes an order carries becameReady true and order status READY, for example `{ "ticket": { ... }, "order": { "id": 1042, "status": "READY", "version": 4, "becameReady": true } }`.

Start (K-03)

Case	Status	Code and notes
Ticket is NEW	200	
Already IN_PROGRESS	409	INVALID_TRANSITION, currentStatus IN_PROGRESS; treat as success
DONE or CANCELLED	409	INVALID_TRANSITION
expectedVersion stale	409	STALE_VERSION with the current ticket
Two cooks start the same ticket	n/a	One 200; the other 409 STALE_VERSION
Order cancelled meanwhile (ticket CANCELLED)	409	INVALID_TRANSITION

Bump (K-04)

Case	Status	Code and notes
Ticket is IN_PROGRESS	200	becameReady true only when it was the last open ticket (BR-06)
Ticket is NEW	409	INVALID_TRANSITION, reason MUST_START_FIRST (SRS open issue OI-01)
Already DONE	409	INVALID_TRANSITION, currentStatus DONE; treat as success
expectedVersion stale	409	STALE_VERSION
The last two tickets of an order bumped at the same moment	n/a	Both return 200; exactly one carries becameReady true; the order becomes READY once (NFR-CONC-04)
Bump and cancel at the same moment	n/a	The order lock serialises them; the loser gets 409

Recall (K-05)

Case	Status	Code and notes
DONE within the recall window	200	Order returns to IN_KITCHEN if it was READY; the token moves back to PREPARING
Window expired	409	INVALID_TRANSITION, reason RECALL_WINDOW_EXPIRED (BR-17)
Order already COMPLETED	409	INVALID_TRANSITION, reason ORDER_COMPLETED
Ticket not DONE	409	INVALID_TRANSITION
expectedVersion stale	409	STALE_VERSION
Recall as the window closes	n/a	The server time inside the transaction decides

Acknowledge a cancelled ticket (K-06)

Case	Status	Code and notes
Cancelled and not yet acknowledged	200	The notice disappears from that station's screens
Already acknowledged	200	No change
Ticket is not CANCELLED	409	INVALID_TRANSITION

For all four: unknown ticket 404; Cashier or Admin 403; a Kitchen user at another station 403; TICKET_ACTION exhausted 429; a missing or invalid expectedVersion on K-03 to K-05 is 422 VALIDATION_FAILED with REQUIRED or OUT_OF_RANGE.

11.3 K-07 GET /kitchen/overview

Manager board (FR-KDS-09). Optional filter stationId (an unknown id returns 422 UNKNOWN_ID). Response: serverTime, sla, orders and lateTickets. orders lists every open order (CREATED, IN_KITCHEN, READY), rush first and then oldest, each as an OrderSummary with its tickets (id, stationId, stationName, status, ageSeconds, percentOfTarget, colour, rush). lateTickets lists open tickets past their red threshold. Role Manager only; others get 403. The same data is pushed on the manager stream, so a late ticket appears within 5 seconds.

12. Status board and streams

12.1 B-01 GET /board

Public and read-only (FR-BRD-01). Response: serverTime, preparing (token numbers, ascending) and ready (token, readySinceSeconds and highlight, oldest first). highlight is true once a token has waited longer than board_ready_highlight_minutes (FR-BRD-04).

```
{
  "serverTime": "2026-10-30T09:30:00.000Z",
  "preparing": [18, 19, 21],
  "ready": [
    { "token": 16, "readySinceSeconds": 410, "highlight": true },
    { "token": 17, "readySinceSeconds": 95, "highlight": false }
  ]
}
```

Case	Status	Notes
Valid call	200	No names, items or amounts are ever included; Cache-Control: no-store
Nothing in progress	200	Both lists empty
Unpaid (CREATED), COMPLETED and CANCELLED orders	n/a	Never shown
A recall moves a READY order back	n/a	Its token returns to preparing
More than 60 requests per minute from one address	429	RATE_LIMITED; boards should use the stream or poll every 3 seconds or slower

12.2 Streams X-01 to X-03

ID	Path	Audience	Token needed	Events
X-01	/stream/stations/{id}	Kitchen (bound), Manager	Yes	hello, TICKET_CREATED, TICKET_CHANGED, TICKET_CANCELLED, CONFIG_CHANGED, SNAPSHOT_REQUIRED, STREAM_CLOSING
X-02	/stream/manager	Manager	Yes	hello, ORDER_CHANGED, TICKET_CHANGED, LATE_TICKET, CONFIG_CHANGED, SNAPSHOT_REQUIRED, STREAM_CLOSING
X-03	/stream/board	Public	No	hello, BOARD_CHANGED, SNAPSHOT_REQUIRED

The request is a GET with Accept: text/event-stream. Authenticated streams use a fetch-based client that sends the Authorization header; the browser's EventSource cannot (SAD 9.6). The response is 200 with Content-Type: text/event-stream, Cache-Control: no-cache and X-Accel-Buffering: no. A Last-Event-ID header is accepted but ignored: there is no replay, and clients always resynchronise from the snapshot endpoint.

Framing. Each event is an event line, an id line (a per-process sequence number, for debugging only) and a data line holding JSON, followed by a blank line. Every 15 seconds the server sends a comment line starting with a colon as a heartbeat.

```
event: TICKET_CHANGED
id: 1842
data: {"ticket": {"id": 5521, "status": "IN_PROGRESS", "version": 1,
"startedAt": "2026-10-30T09:20:05.310Z"}}

: keepalive
```

The data of a ticket event always carries the full Ticket, abbreviated above for space.

Event	Payload	Sent when
hello	serverTime, stream, heartbeatSeconds (15), expiresAt (token expiry; null on the board)	First event on every connection
TICKET_CREATED	ticket	An order is paid and its tickets are created
TICKET_CHANGED	ticket	Start, bump, recall, rush change, acknowledgement
TICKET_CANCELLED	ticket	The order was cancelled
ORDER_CHANGED	order (OrderSummary and tickets summary)	An order's status or rush flag changed
LATE_TICKET	ticketId, orderNumber, stationId, ageSeconds	A ticket crosses its red threshold
CONFIG_CHANGED	sla, recallWindowSeconds	Configuration changed
BOARD_CHANGED	preparing, ready (as in B-01)	Anything that changes the board
SNAPSHOT_REQUIRED	reason: SERVER_SHUTDOWN	Graceful shutdown; fetch the snapshot after reconnecting
STREAM_CLOSING	reason: TOKEN_EXPIRED	Just before the server closes a stream whose token is expiring

Client rules

1. Open the stream and buffer its events; then fetch the snapshot (K-01, K-07 or B-01).
2. Merge the snapshot, then the buffered and live events: keep the highest version of each ticket; replace the whole board payload.
3. Treat no heartbeat for 40 seconds as a dead connection and reconnect.
4. Reconnect with exponential backoff of 1, 2, 4 and 8 seconds, then 15 seconds at most, with random jitter, and repeat step 1.
5. Reconnect with a refreshed token about 30 seconds before expiresAt.

6. Refresh the snapshot every 60 seconds as a safety net. While a stream is down, poll the snapshot every 2 seconds (stations) or 3 seconds (board).
7. Expect duplicates and out-of-order events across tickets; the version merge makes both harmless.

Case	Status	Notes
Valid connection	200	Stream starts with hello
Token missing, invalid or expired (X-01, X-02)	401	JSON error, before any stream starts
Role or station binding not allowed	403	FORBIDDEN
Unknown station	404	NOT_FOUND
Accept excludes text/event-stream and /	406	NOT_ACCEPTABLE
SSE_CONNECT bucket empty, or the per-user, per-address or total cap reached	429	RATE_LIMITED, details.rateClass SSE_CONNECT or CONNECTION_CAP, Retry-After
Token expires while connected	n/a	STREAM_CLOSING then close; reconnect with a new token
Server shutting down	n/a	SNAPSHOT_REQUIRED then close
Client too slow and its queue of 100 events overflows	n/a	The server closes the stream without notice; the client reconnects and resynchronises, so nothing is silently lost
User deactivated while connected	n/a	The stream ends when the token expires, at most 15 minutes later
Proxy buffering enabled	n/a	Events arrive late; fix the Nginx settings (SAD 9.7)

13. Reports and audit

13.1 Rules common to R-01 to R-05

Parameters from and to (business days) are required, from must not be after to, and the range must not exceed 92 days (FR-RPT-06). Responses carry from, to, generatedAt, the rows and, where it makes sense, totals. Money values are strings. A future to date is allowed and simply yields no rows. Reports run in read-only transactions behind a bulkhead of 2 concurrent queries.

Case	Status	Code and notes
from or to missing	422	VALIDATION_FAILED, REQUIRED
from after to, or a range above 92 days	422	VALIDATION_FAILED, INVALID_RANGE
No data in the range	200	rows is empty and totals are zero (0.00)
Both report slots busy for more than 100 ms	429	RATE_LIMITED, details.rateClass REPORT_CONCURRENCY, Retry-After 1
Query exceeds 10 seconds	503	SERVICE_BUSY, details.reason QUERY_TIMEOUT
REPORT bucket (10 per minute) empty	429	RATE_LIMITED, details.rateClass REPORT
Role Cashier or Kitchen	403	FORBIDDEN
Accept: text/csv or format=csv (Could, FR-RPT-07)	200	Same rows as CSV: header row, UTF-8, decimal point, Content-Disposition attachment

R-01 GET /reports/sales. Optional filters paymentMethod and orderType. Rows: businessDay, paymentMethod, orderType, orders, subtotal, gst, total, plus a totals object. Only paid, non-cancelled orders count (SQL S10).

R-02 GET /reports/top-items. Parameters n (1 to 50, default 10) and by (quantity, the default, or revenue). Rows: itemId, name, quantity, revenue; ties broken by name. Combo lines are not counted in version 1 (SQL S11).

R-03 GET /reports/prep-times. Parameters groupBy (station, the default, or item) and an optional stationId. Rows: stationId and stationName, or itemId and name, then tickets, avgSeconds, medianSeconds, p90Seconds and lateShare (0 to 1, four decimals). Time runs from ticket creation to done, for DONE tickets only; a recalled ticket uses its final done time; a late ticket is one whose time exceeded its targetSeconds. Under groupBy item, each item takes the cycle time of the ticket it was on, so items sharing a ticket share its time.

R-04 GET /reports/hourly. Rows for all 24 hours (0 to 23, Asia/Kolkata): hour and orders created, including cancelled ones; hours with no orders show 0, and the rows sum to the number of orders in the range.

R-05 GET /reports/cancellations. Rows: reasonCode, cancelledByRole, orders, sorted by orders descending, plus a total.

13.2 AU-01 GET /audit

Roles Manager and Admin, class REPORT. Filters: entityType (ORDER, TICKET, PAYMENT, REFUND, MENU_ITEM, CATEGORY, MODIFIER, COMBO, STOCK, USER, STATION, CONFIG), entityId (needs entityType), actorId, action (up to 40 characters), from and to (instants). Sort and paging as in section 2.6; occurredAt descending, with cursor mode available. Without from and to the window is the last 7 days; without an entity filter a window cannot exceed 92 days.

```
{
  "id": 880412, "occurredAt": "2026-10-30T09:16:12.004Z", "actorId": 3,
"actorRole": "CASHIER",
  "entityType": "ORDER", "entityId": 1042, "action": "ORDER_PAID",
  "fromState": "CREATED", "toState": "PAID", "reason": null,
  "correlationId": "9b2f6c1e-7d54-4a39-8c0e-2f1d7a6b5e44", "details": {
"paymentId": 981 }
}
```

Actions recorded include ORDER_CREATED, ORDER_EDITED, ORDER_PAID, ORDER_IN_KITCHEN, ORDER_READY, ORDER_COMPLETED, ORDER_CANCELLED, ORDER_RUSH_CHANGED, TICKET_STARTED, TICKET_BUMPED, TICKET_RECALLED, TICKET_CANCELLED, PAYMENT_RECORDED, REFUND_CREATED, REFUND_COMPLETED, ITEM_CREATED, ITEM_UPDATED, ITEM_DELETED, ITEM_AVAILABILITY_CHANGED, STOCK_ADJUSTED, USER_CREATED, USER_UPDATED, PASSWORD_RESET, STATION_CHANGED, CONFIG_CHANGED and LOGIN_LOCKED.

Case	Status	Code and field code
Valid call	200	p95 under 300 ms with 500,000 records (FR-AUD-03)
entityId without entityType	422	VALIDATION_FAILED, REQUIRED on entityType
entityType not in the list	422	VALIDATION_FAILED, INVALID_ENUM
from after to, or a range above 92 days without an entity filter	422	VALIDATION_FAILED, INVALID_RANGE
cursor together with page	400	MALFORMED_REQUEST
Nothing matches	200	Empty content
Role Cashier or Kitchen	403	FORBIDDEN
Any attempt to change or delete an audit record	n/a	No endpoint exists, and the database refuses it (FR-AUD-02)

14. Platform endpoints

- **H-01 GET /actuator/health** (and the liveness and readiness variants) is public and returns an object with status UP, or status DOWN with HTTP 503 when the database is unreachable or migrations are not applied. No component details are exposed publicly.
- **H-02 GET /actuator/prometheus** serves metrics on the internal management port, which Nginx does not publish. If it is ever exposed on the main port it requires the ADMIN role (FR-SYS-05).
- **H-03 GET /v3/api-docs** and the Swagger page are enabled in the dev and Compose profiles and restricted to Admin elsewhere. The generated definition must match this document; a contract test compares them (section 16).
- HEAD is supported on every GET endpoint except streams, with the same headers and no body. OPTIONS is answered by the CORS preflight. Unknown paths return 404 after authentication.

15. Cross-cutting cases

15.1 Typical call sequences

A. Start of shift. A-01 login, A-04 me, S-01 stations, M-01 menu (keep the ETag). A kitchen screen then opens K-01 and X-01.

B. Counter order, happy path.

1. M-01 with If-None-Match to refresh the menu.
2. O-01 with a new Idempotency-Key.
3. P-01 payment; P-03 for the bill.
4. Kitchen screens receive TICKET_CREATED on X-01; each station calls K-03 and then K-04.
5. After the last bump the order is READY and the token moves to READY on B-01 and X-03.
6. O-06 when the food is handed over.

C. Cancellation. O-05 by the Cashier before payment; after payment only a Manager can cancel.

D. Mistaken bump. K-05 within the recall window.

E. Token expires mid-shift. Any call returns 401: refresh with A-02 (or log in again), retry the call and reconnect the streams.

F. Network failure while creating an order. Retry O-01 with the same Idempotency-Key. Never generate a new key for the same attempt.

G. Network failure while paying. Call P-02: 200 means the payment succeeded; 404 means retry P-01.

H. An item sells out. O-01 returns 409 OUT_OF_STOCK; the screen reloads M-01. **I. A Manager marks an item unavailable (M-17).** Cashiers see it on their next M-01.

15.2 Concurrency and conflict matrix

Two simultaneous operations	Outcome	Loser's response	Client action
Two O-01 with the same key	One order	Replay with Idempotency-Replayed	None

Two simultaneous operations	Outcome	Loser's response	Client action
P-01 and P-01 on one order	One payment	409 PAYMENT_ALREADY_RECORDED	Call P-02
P-01 and O-05 on a CREATED order	Whoever locks the order first	409	Re-read the order
P-01 and O-04	Edit after payment gets 409; payment with the old amount after an edit gets 422	409 or 422 AMOUNT_MISMATCH	Re-read and pay the current total
O-04 and O-04	One edit wins	409 STALE_VERSION	Re-read and re-apply
K-03 and K-03 on one ticket	One wins	409 STALE_VERSION	Treat as success if the ticket is IN_PROGRESS
K-04 and K-04 on one ticket	One wins	409 STALE_VERSION or INVALID_TRANSITION (already DONE)	Treat as success
K-04 on the last two tickets of an order	Both succeed; exactly one reports becameReady	None	None
K-04 and O-05	The order lock serialises them	409	Re-read
K-05 and O-06	If complete wins, recall gets 409 ORDER_COMPLETED; if recall wins, complete gets 409	409	Re-read
O-01 and M-17 (availability)	Each create reads availability inside its own transaction; an order already committed stands	None	None
Several O-01 for the last stock unit	One order wins	409 OUT_OF_STOCK for the others	Reload the menu
O-01 and a price change	The order is priced with the price it read	None	Show the server's totals

Two simultaneous operations	Outcome	Loser's response	Client action
I-02 and O-01	Serialised by the conditional stock update	409 OUT_OF_STOCK or 422 NEGATIVE_STOCK	Re-read stock
Unpaid timeout and P-01	The job skips locked rows; if the job wins, payment gets 409 INVALID_TRANSITION (CANCELLED)	409	Create a new order
C-02 and any request	Requests that begin after the commit use the new values	None	None
U-04 deactivation and an open session	Tokens stay valid until expiry, at most 15 minutes	None	The next refresh fails
Two A-02 with the same cookie	One new token; the second gets 401 (a 10-second grace window prevents revocation)	401	Refresh from one place only

15.3 Retry guidance

Situation	Safe to retry?	How
GET and HEAD	Yes	Any time, with backoff
POST /orders with an Idempotency-Key	Yes	Same key, same payload
POST /orders without a key	No	Search GET /orders for the order first
POST /orders/{id}/payments	Only after P-02 returns 404	Otherwise the payment already exists
Ticket actions	Yes, after re-reading	Repeating after success gives 409; INVALID_TRANSITION with the target state already reached is success

Situation	Safe to retry?	How
PUT, PATCH, DELETE	When the target state is identical	PATCH with expectedVersion: a repeat after success gives 409 STALE_VERSION, so re-read
Cancel and complete	Yes	A repeat returns 409 with currentStatus equal to the target; treat as success
429	Yes	After Retry-After plus jitter
503	Yes	Backoff of 1, 2 and 4 seconds, at most 3 attempts; writes only when idempotent
500	Do not auto-retry writes	Report the correlationId
Network error or timeout	Outcome unknown	Read the resource before repeating a write

15.4 Time and business-day cases

Case	Behaviour
Device clocks differ	Clients use serverTime and server timestamps; ages are computed from them
Order near the cutoff	The business day is decided by the server time at creation
Cutoff changed in configuration	Refused while any order is open (7.2)
Daylight saving time	Not applicable in Asia/Kolkata; storage is UTC
Reports across the cutoff	Grouped by business day, never by calendar day
Timestamp precision	Milliseconds
Future dates in filters	Accepted; results are empty

15.5 Limits

Values marked (proposed) are new limits added by this document (section 17.2).

Item	Limit
Username	3 to 50 characters
Login password	Up to 128 bytes
New or reset password	8 to 72 bytes
Station, category, modifier or group name	1 to 40, 60, 60 and 60 characters
Item and combo name	1 to 80 characters
Item description	Up to 300 characters
Prices and price changes	0.01 to 99999.99 (proposed); price changes may be negative but never below minus the base price
Target preparation time	1 to 7200 seconds
Stations per item	1 to 10
Modifier groups per item; modifiers per group	Up to 10 and up to 20 (proposed)
Combo components	1 to 10
Order lines; quantity per line	1 to 30 (proposed); 1 to 50
Modifier ids per line	Up to 20
Order note; cancel text; stock reason	Up to 200 characters
Payment reference	Up to 64 characters
Idempotency-Key; correlation id	Up to 80 and up to 64 characters
Stock adjustment	Minus 100000 to 100000
Page size; filter values	Up to 100; up to 10
Top-items n	1 to 50
Report and order-search range	Up to 92 days

Item	Limit
Request body	Up to 1 MB

16. Testing the contract

16.1 Test layers

Layer	What it checks	Gate
Case tests	One table-driven test for every row of every case table in this document, named after the endpoint ID and the row	Every row passes
Role matrix	Every endpoint against every role and an anonymous caller, as in section 4 (AT-08)	No unexpected 200
Schema validation	Every response is validated against the generated OpenAPI schema and every error against the envelope; money matches the string format; no undocumented fields	Zero violations
Example tests	Every JSON example in this document is parsed and replayed in CI, and its totals are recomputed independently with the BR-03 formulas	Examples never drift
Contract drift	A script compares the generated OpenAPI file with the endpoint index in section 4 (IDs, methods, paths, roles, classes)	Any mismatch fails the build
Compatibility	openapi-diff against the last release	Removed or retyped fields fail the build
Concurrency over HTTP	AT-03 to AT-06 with 50 threads through the API, repeated 50 times	Pass; mutation check turns them red

Layer	What it checks	Gate
Streams	Connect, hello, event within 1 second of a payment, heartbeat, reconnect and resynchronise, queue overflow close, token-expiry close	Pass
Rate limits	Every class: burst used up gives 429 with Retry-After, refill works, users are isolated, and the design workload sees no 429	Pass
Fault injection	Ticket creation fails after payment (AT-11); a lock timeout returns 503	No partial state
Security	Station binding, unknown properties, oversized body, wrong content types, CORS preflight, security headers	Pass

16.2 Acceptance scenarios and endpoints

Scenario (SRS 12.2)	Endpoints exercised
AT-01 Happy path	M-01, O-01, P-01, K-03, K-04, B-01, O-06, AU-01
AT-02 Validation	O-01
AT-03 Idempotent retry	O-01
AT-04 Last item race	O-01, I-02, M-17
AT-05 Concurrent ticket update	K-03, K-04
AT-06 Recall	K-04, K-05, B-01
AT-07 Cancellation rules	O-05
AT-08 Access control	All endpoints
AT-09 Reconnect	X-01, K-01
AT-10 Reports	R-01 to R-05
AT-11 Fault injection	P-01

16.3 Artefacts

The generated OpenAPI file is committed with each release. A Bruno or Postman collection is generated from it and extended with the sequences in section 15.1; the README's demo script uses that collection.

17. Traceability, proposed changes and next steps

17.1 Traceability

Requirements	Addressed in
FR-AUTH-01 to 07	Sections 2.2 and 6
FR-MENU-01 to 08	Section 7
FR-INV-01 to 05	Section 8
FR-ORD-01 to 12	Section 9
FR-PAY-01 to 08	Section 10
FR-KDS-01 to 10, FR-BRD-01 to 04	Sections 11 and 12
FR-RPT-01 to 07, FR-AUD-01 to 04	Section 13
FR-CFG-01, FR-SYS-01 to 05	Sections 2, 7.2 and 14
BR-15, FR-ORD-10	Section 2.7
NFR-CONC-01 to 04	Sections 2.7, 2.8, 11 and 15.2
NFR-SEC-02	Section 2.1 (unknown input)
SRS section 10 (errors)	Section 3

17.2 Proposed changes to the SRS, DBD and SAD

SRS (for v0.2)

1. Add error codes METHOD_NOT_ALLOWED, NOT_ACCEPTABLE, RESOURCE_IN_USE, PAYLOAD_TOO_LARGE, UNSUPPORTED_MEDIA_TYPE and SERVICE_BUSY. Clarify that INVALID_TRANSITION means an operation not allowed in the current state, and state the ITEM_UNAVAILABLE versus VALIDATION_FAILED rule of section 9.1.

2. Add as Should: change-password (A-05), admin password reset (U-05), refund completion (P-06) and the stock list (I-01). In FR-AUTH-06, state that unknown usernames are throttled like known ones.
3. Add validation limits: at most 30 lines per order, 10 modifier groups per item, 20 modifiers per group, prices of at most 99999.99, passwords of 8 to 72 bytes.
4. State two API rules as requirements: unknown properties and query parameters are rejected, and money is carried as strings.
5. FR-ORD-09: add the cursor mode and the 92-day range cap.
6. FR-KDS-05: add the SNAPSHOT_REQUIRED and STREAM_CLOSING events.
7. FR-RPT-03: define the per-item measure as the cycle time of the item's ticket.

DBD (for v0.2)

8. Grant DELETE on menu_item, modifier_group, modifier, item_stock and combo to kf_app. Rows referenced by orders, combos or stock history stay protected by their foreign keys, which is what lets M-09, M-13, M-16 and M-21 delete only unused rows.
9. Add statement S12b (preparation times per item, through ticket_item) and S14 (cancellations by reason and by the cancelling user's role, joining orders to app_user on cancelled_by).

SAD (for v0.2)

10. Section 5.2: add the REPORT_CONCURRENCY and CONNECTION_CAP rate details and the guidance for polling boards. Section 9: add the STREAM_CLOSING event.

17.3 Open items

ID	Item	Decide in
OI-01	Should Admin be able to read orders and tickets? Today only Cashier and Manager can	SRS v0.2
OI-02	Confirm the refresh-token lifetime (8 hours) and the cookie settings	Phase 1
OI-03	Confirm the price ceiling of 99999.99	SRS v0.2
OI-04	Whether stations and categories also need expectedVersion; they are last-write-wins today	Document 6
OI-05	Build the cursor mode in version 1, or defer it as Could	Phase 3

ID	Item	Decide in
OI-06	Include the printable PDF bill (Could) in version 1	Phase 4

17.4 Next step

Document 6, the Low-Level Design: class and package design for each module, the state machines in code form, sequence diagrams for the main flows, how errors map from exceptions to this document's codes, and how the mechanisms of documents 3 to 5 are implemented.

Version	Date	Author	Change
0.1	30 October 2026	Rathi	First draft